

Statement of Applicability

ISO/IEC 27001:2022 - Annex A Control Set

SecurityGroup101 | Enterprise GRC Program

Prepared By: Maxine Jones, GRC Analyst | Reviewed By: Chief Information Security Officer

Version 1.0 | Classification: Confidential – Internal Use

1. Purpose and Scope

This Statement of Applicability (SoA) documents which Annex A controls from ISO/IEC 27001:2022 are applicable to SecurityGroup101's Information Security Management System (ISMS), the justification for each applicability decision, current implementation status, supporting evidence reference, and the accountable control owner. It covers the in-scope environment supporting SecurityGroup101's cloud-based payment processing platform, including the cardholder data environment (CDE), supporting cloud infrastructure, and corporate IT systems used to administer the platform. Status reflects the program's current position within the 18-month GRC Roadmap rather than a fully mature, steady-state ISMS.

2. Methodology

Each of the 93 controls in ISO/IEC 27001:2022 Annex A was evaluated against the outcomes of the organization's quantitative risk assessment (NIST SP 800-30 methodology), the GLBA, PCI DSS, and FFIEC gap analyses, and the unified control catalog. A control is marked Applicable where it addresses an identified risk or a legal, regulatory, or contractual obligation. A control is marked Not Applicable only where the organization has no corresponding asset, process, or exposure for that control, with the rationale documented in the Justification column. Implementation status uses the same definitions as the control catalog: Implemented (fully deployed and operational), Partial (implemented but incomplete or inconsistent), In Progress (actively being built, e.g. the new vendor risk program), Draft (defined but not yet implemented), Planned (scheduled in a later roadmap phase), and Gap (not yet implemented).

3. Summary

Implementation Status	Control Count
Implemented	24
Partial	39
In Progress	4
Draft	15
Planned	4
Gap	4
Not Applicable	3

Of the 93 Annex A controls, three are marked Not Applicable (A.7.6, A.7.11, A.7.12), tied to the absence of a company-operated data center, since SecurityGroup101 hosts production infrastructure entirely with a certified cloud IaaS provider under a shared-responsibility model. The remaining controls are predominantly Partial, Draft, or Planned, consistent with the gaps already identified in the GLBA, PCI DSS, and FFIEC assessments and the program's position in Phase 1-2 of the GRC Roadmap. Controls marked In Progress (A.5.19-A.5.22, A.8.30) reflect the new Third-Party Risk Assessment Program, which directly remediates the vendor risk management gap identified in the GLBA Gap Analysis.

A.5 Organizational Controls

ID	Title	Appl	Justification	Status	Evidence Reference	Owner
A.5.1	Policies for information security	Y	Information Security Program Charter drafted; pending CISO and board approval per Roadmap Phase 2.	Draft	ISP-001 (draft), GRC Roadmap Phase 2	CISO
A.5.2	Information security roles and responsibilities	Y	Governance Model defines roles; board-level reporting cadence not yet operational.	Partial	Governance Model sec. 3	CISO
A.5.3	Segregation of duties	Y	SOX ITGC requires separation between development, change approval, and production access; not yet formally validated.	Partial	Control Catalog AC-03	IT Risk Mgr
A.5.4	Management responsibilities	Y	Executive oversight defined in Governance Model; FFIEC review rates governance oversight as Partial.	Partial	FFIEC Alignment - Governance domain	CISO
A.5.5	Contact with authorities	Y	Required for breach notification to state regulators; formal contact protocol not yet documented.	Draft	Disaster Recovery Plan sec. Communications	Legal/Compliance
A.5.6	Contact with special interest groups	Y	Threat-sharing participation identified as a roadmap activity, not yet active.	Planned	GRC Roadmap Phase 3	SecOps Lead
A.5.7	Threat intelligence	Y	FFIEC Alignment rates threat intelligence integration as Minimal; not yet incorporated into detection workflows.	Gap	FFIEC Alignment - Threat Intelligence domain	SecOps Lead
A.5.8	Information security in project management	Y	Security gate required in SDLC; formal gate not yet defined.	Draft	GRC Roadmap Phase 2	PMO
A.5.9	Inventory of information and other associated assets	Y	Asset inventory validation is an active Phase 1 roadmap activity.	Partial	GRC Roadmap Phase 1	IT Ops
A.5.10	Acceptable use of information and other associated assets	Y	Required for employee handling of cardholder and customer PII.	Draft	GRC Roadmap Phase 2 (core policy set)	HR/CISO
A.5.11	Return of assets	Y	Required at termination to protect access to financial data.	Partial	Control Catalog AC-03 (least privilege)	HR
A.5.12	Classification of information	Y	Required to distinguish cardholder data, PII, and public data; standard not yet published.	Draft	GLBA Gap Analysis sec. 3 (Data Protection)	CISO
A.5.13	Labelling of information	Y	Dependent on completion of the data classification standard (A.5.12).	Draft	GLBA Gap Analysis sec. 3	CISO
A.5.14	Information transfer	Y	Encryption in transit implemented; standardization across all transfer channels still in progress.	Partial	Control Catalog DS-02 / DS-01	IT Security
A.5.15	Access control	Y	Access Control Policy in draft; least-privilege and RBAC enforcement inconsistent.	Partial	Control Catalog AC-01, AC-03	IAM Team
A.5.16	Identity management	Y	No formal joiner/mover/leaver (JML) process yet, per GLBA Gap Analysis.	Partial	GLBA Gap Analysis sec. 2 (Access Controls)	IAM Team
A.5.17	Authentication information	Y	MFA enforcement is inconsistent across administrative and remote access.	Partial	Control Catalog AC-02	IAM Team
A.5.18	Access rights	Y	Privileged access is not regularly reviewed; no formal recertification cadence.	Partial	GLBA Gap Analysis sec. 2	IAM Team
A.5.19	Information security in supplier relationships	Y	No formal TPRM program previously existed per GLBA Gap Analysis; addressed by the new Third-Party Risk Assessment Program.	In Progress	Third-Party Risk Assessment Program	Vendor Risk Mgr

ID	Title	Appl	Justification	Status	Evidence Reference	Owner
A.5.20	Addressing information security within supplier agreements	Y	Security requirements were inconsistently defined in vendor contracts; standard addendum now in development.	In Progress	Third-Party Risk Assessment Program sec. 7	Legal/Procurement
A.5.21	Managing information security in the ICT supply chain	Y	Builds on the new vendor criticality tiering model for cloud and payment subprocessors.	In Progress	Third-Party Risk Assessment Program sec. 4	Vendor Risk Mgr
A.5.22	Monitoring, review and change management of supplier services	Y	Annual reassessment cadence defined for Critical-tier vendors; not yet executed on a full cycle.	Planned	Third-Party Risk Assessment Program sec. 7	Vendor Risk Mgr
A.5.23	Information security for use of cloud services	Y	Core control given IaaS/SaaS dependency for the payments platform.	Partial	GRC Roadmap Phase 3	Cloud Security Lead
A.5.24	Information security incident management planning and preparation	Y	Incident Response Plan exists in draft form per Control Catalog (RS-01).	Draft	Control Catalog RS-01	SecOps Lead
A.5.25	Assessment and decision on information security events	Y	Triage criteria depend on completion of the draft Incident Response Plan.	Draft	Control Catalog RS-01	SecOps Lead
A.5.26	Response to information security incidents	Y	Response procedures drafted; not yet exercised through a live incident or full simulation.	Draft	Disaster Recovery Plan sec. Activation	SecOps Lead
A.5.27	Learning from information security incidents	Y	Post-incident review process not yet established, per Control Catalog (RC-01).	Gap	Control Catalog RC-01	SecOps Lead
A.5.28	Collection of evidence	Y	Required to support regulatory inquiry; formal evidence-handling procedure not yet documented.	Draft	GRC Roadmap Phase 2	SecOps Lead
A.5.29	Information security during disruption	Y	Addressed through the Business Continuity Plan; recurring testing program defined.	Partial	Business Continuity Plan sec. Testing	BCM Lead
A.5.30	ICT readiness for business continuity	Y	Disaster Recovery Plan is implemented and tested per the DR/BCP Testing Schedule.	Implemented	Disaster Recovery Plan; DR Testing Schedule	BCM Lead
A.5.31	Legal, statutory, regulatory and contractual requirements	Y	GLBA, PCI DSS, FFIEC, and SOX obligations are mapped in the compliance crosswalks.	Implemented	GLBA/PCI DSS/FFIEC compliance documents	Compliance
A.5.32	Intellectual property rights	Y	Required to protect proprietary payment-processing software.	Implemented	IP Protection Policy	Legal
A.5.33	Protection of records	Y	Required for financial recordkeeping under SOX and GLBA.	Partial	GRC Roadmap Phase 2	Compliance
A.5.34	Privacy and protection of PII	Y	Privacy program exists at a foundational level; formal charter not yet finalized.	Partial	GRC Roadmap Phase 2	DPO/Privacy Lead
A.5.35	Independent review of information security	Y	Internal audit function not yet formally established; planned for Phase 4 of the roadmap.	Planned	GRC Roadmap Phase 4	Internal Audit
A.5.36	Compliance with policies, rules and standards for information security	Y	Dependent on completion of the core policy set under development in Phase 2.	Partial	GRC Roadmap Phase 2	Compliance
A.5.37	Documented operating procedures	Y	Operational runbooks exist for DR/BCP; broader IT operating procedures still in development.	Partial	DR Testing Schedule; GRC Roadmap Phase 2	IT Ops

A.6 People Controls

ID	Title	Appl	Justification	Status	Evidence Reference	Owner
A.6.1	Screening	Y	Background checks required for staff with access to cardholder data.	Implemented	HR Background Check Procedure	HR
A.6.2	Terms and conditions of employment	Y	Confidentiality and acceptable-use terms required at hire.	Implemented	Employment Agreement Template	HR
A.6.3	Information security awareness, education and training	Y	Formal recurring training program not yet established; planned under Roadmap Phase 2-3.	Partial	GRC Roadmap Phase 2-3	CISO
A.6.4	Disciplinary process	Y	Required to enforce consequences for policy violations.	Implemented	HR Disciplinary Policy	HR
A.6.5	Responsibilities after termination or change of employment	Y	Tied to the JML process identified as a gap in the GLBA Gap Analysis.	Partial	GLBA Gap Analysis sec. 2	HR/IAM
A.6.6	Confidentiality or non-disclosure agreements	Y	Required for staff and contractors handling cardholder data.	Implemented	NDA Template	Legal/HR
A.6.7	Remote working	Y	Remote work procedures defined in the BCP; MFA enforcement for VPN access is inconsistent.	Partial	Business Continuity Plan - Remote Work Enablement	IT Security
A.6.8	Information security event reporting	Y	Reporting path exists informally; not yet integrated with the draft Incident Response Plan.	Draft	Control Catalog RS-01	SecOps Lead

A.7 Physical Controls

ID	Title	Appl	Justification	Status	Evidence Reference	Owner
A.7.1	Physical security perimeters	Y	Applies to corporate office space.	Implemented	Physical Security Standard	Facilities
A.7.2	Physical entry	Y	Badge access control required for office entry.	Implemented	Physical Security Standard sec. 3	Facilities
A.7.3	Securing offices, rooms and facilities	Y	Required for areas housing workstations with cardholder data access.	Implemented	Physical Security Standard sec. 4	Facilities
A.7.4	Physical security monitoring	Y	CCTV and visitor logging required at primary office.	Implemented	Physical Security Standard sec. 5	Facilities
A.7.5	Protecting against physical and environmental threats	Y	Required for any company-operated office space.	Implemented	Facilities Risk Assessment	Facilities
A.7.6	Working in secure areas	N	No company-operated data center; production infrastructure is hosted entirely with a certified cloud IaaS provider under a shared-responsibility model.	Not Applicable	Cloud Security Standard sec. 2 (shared responsibility)	Cloud Security Lead
A.7.7	Clear desk and clear screen	Y	Required for staff handling printed or displayed cardholder data.	Implemented	Acceptable Use Policy sec. 6	HR/CISO
A.7.8	Equipment siting and protection	Y	Applies to office-based workstations and network equipment.	Implemented	Physical Security Standard sec. 6	IT Ops
A.7.9	Security of assets off-premises	Y	Required for laptops used in remote and hybrid work.	Partial	Business Continuity Plan - Remote Work Enablement	IT Security
A.7.10	Storage media	Y	Required for secure handling of removable media containing financial data.	Implemented	Media Handling Procedure	IT Security
A.7.11	Supporting utilities	N	Power, cooling, and utility resilience are managed by the cloud IaaS provider as part of their certified data center operations.	Not Applicable	Cloud Provider attestation (SOC 2 / ISO 27001)	Cloud Security Lead
A.7.12	Cabling security	N	No company-operated data center cabling; cloud provider manages physical infrastructure.	Not Applicable	Cloud Provider attestation (SOC 2 / ISO 27001)	Cloud Security Lead
A.7.13	Equipment maintenance	Y	Applies to office endpoint and network hardware maintenance.	Implemented	IT Asset Maintenance Procedure	IT Ops
A.7.14	Secure disposal or re-use of equipment	Y	Required to prevent data remanence on retired endpoints and media.	Implemented	Media Disposal Procedure	IT Security

A.8 Technological Controls

ID	Title	Appl	Justification	Status	Evidence Reference	Owner
A.8.1	User end point devices	Y	Endpoint hardening baseline in development under Roadmap Phase 3.	Partial	GRC Roadmap Phase 3	IT Security
A.8.2	Privileged access rights	Y	Privileged access is not regularly reviewed, per GLBA Gap Analysis.	Partial	GLBA Gap Analysis sec. 2	IAM Team
A.8.3	Information access restriction	Y	Role-based restriction defined but inconsistently enforced for CDE access.	Partial	Control Catalog AC-03	IAM Team
A.8.4	Access to source code	Y	Required to protect proprietary payment-processing code.	Implemented	Source Code Access Procedure	Engineering Lead
A.8.5	Secure authentication	Y	MFA is not consistently enforced for administrative or remote access.	Partial	Control Catalog AC-02; PCI DSS Crosswalk Req. 8.3	IAM Team
A.8.6	Capacity management	Y	Required to maintain availability of payment-processing infrastructure.	Implemented	Capacity Management Procedure	Cloud Ops
A.8.7	Protection against malware	Y	Endpoint protection deployed; coverage validation in progress.	Partial	GRC Roadmap Phase 3	IT Security
A.8.8	Management of technical vulnerabilities	Y	Vulnerability management process exists without defined remediation SLAs, per Control Catalog and PCI DSS Crosswalk.	Partial	Control Catalog IP-01, IP-02; PCI DSS Crosswalk Req. 6.2	SecOps Lead
A.8.9	Configuration management	Y	Hardened baselines required per PCI DSS Req. 2; standardization in progress.	Partial	GRC Roadmap Phase 3	Cloud Ops
A.8.10	Information deletion	Y	Retention limits defined; automated enforcement not yet implemented.	Partial	GRC Roadmap Phase 2	Compliance/IT
A.8.11	Data masking	Y	No data masking control currently implemented for non-production environments.	Gap	GLBA Gap Analysis sec. 3 (Data Protection)	Engineering Lead
A.8.12	Data leakage prevention	Y	No DLP controls currently implemented, per Control Catalog (DS-03).	Gap	Control Catalog DS-03; GLBA Gap Analysis sec. 3	IT Security
A.8.13	Information backup	Y	Backup processes implemented and validated through monthly restoration testing.	Implemented	DR Testing Schedule - Backup Restore Test	Cloud Ops
A.8.14	Redundancy of information processing facilities	Y	Multi-region failover defined for Tier 1 payment-processing systems.	Implemented	Disaster Recovery Plan sec. Recovery Tiers	Cloud Ops
A.8.15	Logging	Y	SIEM coverage limited to a subset of systems, per FFIEC Alignment and Control Catalog (DE-01).	Partial	Control Catalog DE-01; FFIEC Alignment - Security Monitoring	SecOps Lead
A.8.16	Monitoring activities	Y	Detection use cases and correlation rules are limited in scope.	Partial	FFIEC Alignment - Security Monitoring domain	SecOps Lead
A.8.17	Clock synchronization	Y	Required to support reliable log correlation across distributed systems.	Implemented	IT Operations Runbook Library	IT Ops
A.8.18	Use of privileged utility programs	Y	Restriction of privileged tooling not yet formally enforced.	Partial	Control Catalog AC-02	IAM Team
A.8.19	Installation of software on operational systems	Y	Change approval process exists; software installation controls not fully enforced.	Partial	GRC Roadmap Phase 3	Cloud Ops
A.8.20	Networks security	Y	Network segmentation has not been formally validated, per PCI DSS Crosswalk.	Partial	PCI DSS Crosswalk Req. 1.2	Network Security
A.8.21	Security of network services	Y	Required for vendor-provided network and connectivity services.	Partial	PCI DSS Crosswalk Req. 1.2	Network Security

ID	Title	Appl	Justification	Status	Evidence Reference	Owner
A.8.22	Segregation of networks	Y	CDE segmentation not yet formally documented or tested, per PCI DSS Crosswalk.	Partial	PCI DSS Crosswalk Req. 1.2	Network Security
A.8.23	Web filtering	Y	Required to reduce exposure to malicious sites from corporate endpoints.	Implemented	Endpoint Security Standard sec. 5	IT Security
A.8.24	Use of cryptography	Y	Encryption in transit implemented; encryption at rest not yet standardized, per PCI DSS Crosswalk and Control Catalog (DS-01).	Partial	PCI DSS Crosswalk Req. 3.4; Control Catalog DS-01	IT Security
A.8.25	Secure development life cycle	Y	Security gates within the SDLC are planned but not yet formalized.	Draft	GRC Roadmap Phase 2	Engineering Lead
A.8.26	Application security requirements	Y	Application security requirements not yet formally documented.	Draft	GRC Roadmap Phase 2	Engineering Lead
A.8.27	Secure system architecture and engineering principles	Y	Defense-in-depth principles applied inconsistently across the platform.	Partial	GRC Roadmap Phase 3	Engineering Lead
A.8.28	Secure coding	Y	Secure coding standard not yet formally adopted, per PCI DSS Req. 6.2.	Draft	PCI DSS Crosswalk Req. 6.2	Engineering Lead
A.8.29	Security testing in development and acceptance	Y	Formal security testing gate (SAST/DAST, penetration testing) not yet established.	Draft	GRC Roadmap Phase 3	AppSec Lead
A.8.30	Outsourced development	Y	Applies where contracted developers support platform features; security clauses required in contracts.	In Progress	Third-Party Risk Assessment Program sec. 7	Engineering Lead
A.8.31	Separation of development, test and production environments	Y	Environment separation implemented per PCI DSS Req. 6.4.	Implemented	Environment Separation Standard	Cloud Ops
A.8.32	Change management	Y	Change approval process exists; consistency of enforcement still maturing.	Partial	GRC Roadmap Phase 3	Change Advisory Board
A.8.33	Test information	Y	Use of live cardholder data in test environments not yet formally prohibited by policy.	Partial	GLBA Gap Analysis sec. 3	Engineering Lead
A.8.34	Protection of information systems during audit testing	Y	No formal internal audit function yet established; safeguards to be defined alongside Phase 4 audit program.	Planned	GRC Roadmap Phase 4	Internal Audit

4. Review and Approval

This Statement of Applicability is reviewed at least annually and upon material change to the organization's risk environment, regulatory obligations, or technology footprint. Controls in Draft, Planned, or Gap status are tracked to closure through the GRC Roadmap (Phases 2-4) and reported to the ISMS Steering Committee on a quarterly basis.